PORTFOLIO CASE STUDY · MDM-D15

MDM GRC Readiness & Control Assurance

Master Portfolio

A readiness assessment and control assurance case study for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company.

14 DELIVERABLES · SIX PHASES

D01 D02 D03 D04 D05 D06 D07 D08 D09 D10 D11 D12 D13 D14

Prepared by

Ali Fathi Aldhabiki

Cybersecurity Governance, Risk & Compliance (GRC)

linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Frameworks

SAMA Cyber Security Framework v1.0 | NCA Essential Cybersecurity Controls (ECC-2:2024)

NOTICE

The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

The Project

This portfolio summarizes a 14-deliverable GRC case study. This page describes the project: the problem, the question, the objectives, the scope and the method. The results of the simulated assessment are on the next page, kept apart from the description of the work.

THE PROBLEM

A fictional Saudi financing company with 850 employees lets staff use personal phones and tablets for work (BYOD) but has no mobile device management. It cannot see which devices hold corporate data, enforce protection on them, or remove that data. Management asked for a readiness assessment after four recurring problems:

1. **Lost or stolen devices** → MDM-RSK-001
2. **Access not removed when people leave** → MDM-RSK-007
3. **Devices not updated** → MDM-RSK-003
4. **Data copied to personal storage** → MDM-RSK-002

The selected response is Microsoft Intune with Microsoft Entra ID: full management for company-owned devices, and app protection without enrollment for BYOD.

THE QUESTION

Is the company ready to run mobile access to corporate data under defined, testable controls?

OBJECTIVES

OBJ-01	Define the mobile service, its assets and who is responsible.
OBJ-02	Assess the risks of the current state and of introducing MDM.
OBJ-03	Define control requirements and map them to recognized frameworks.
OBJ-04	Define how each control is evidenced and tested.
OBJ-05	Turn test results into gaps, remediation and risk treatment.
OBJ-06	Give management a readiness position and a decision to make.

SCOPE

In scope: mobile access to Microsoft 365 from Android and iOS/iPadOS; company-owned devices and approved personal devices; Microsoft Intune, Entra ID and Conditional Access.

Out of scope: Windows and macOS, privileged administration from mobile devices, contractors on personal devices, and live tenant configuration.

METHOD

Six phases, each using the output of the one before: **Define → Assess risk → Design controls → Evidence and test → Remediate → Report.** Every record carries an ID that links it to the record above it, from asset to management decision.

What Was Produced and What It Found

WHAT WAS PRODUCED

9 assets	**8** risks	**8** controls	**35** technical requirements
4 access policies	**75** evidence items	**10** control tests	**9 / 12** findings / recommendations

- A risk method and register with a Risk Owner for each risk, separate from the control owner.
- A control crosswalk to SAMA CSF v1.0 and NCA ECC-2:2024, with the limit of each mapping recorded.
- A BYOD policy, a technical standard and a Conditional Access design, each traceable to the controls.
- A risk-based test sample with pass conditions set before testing, and a list of untested requirements with the reason.
- Gap analysis, recommendations with owner, due date and success measure, Risk Owner decisions, a readiness dashboard and an executive report.
- Independence built in: operations perform access reviews, GRC tests them, and Internal Audit retests work GRC prepared.

SIMULATED ASSESSMENT RESULTS

MDM-D14, as at 16 November 2026 | Simulated values

RISK LEVEL (tested scope)

MEDIUM

All five assessed risks are at Medium. The highest is MDM-RSK-002 at Medium (9), provisional. Three of the eight risks are not assessed yet.

READINESS STATUS

NOT READY

Only 2 of 10 tests were effective (20%). No control is rated Implemented.

Top gaps	Corporate data can leave managed control on iOS; four requirement areas have no control or owner; part of the scope is untested.
Immediate action	MDM-REC-002, owned by the IT Operations Manager. Retest due 14 February 2027.
Management decision	Approve the next test cycle and set its date.

Medium risk does not mean ready, and Not Ready does not mean High risk. These are simulated results. They show the method, not a real environment.

PROJECT OVERVIEW

Deliverables Roadmap

Six phases, fourteen deliverables. Each phase uses the output of the one before it. Select a deliverable to open its page.

1 DEFINE

Sets what is protected and who is accountable.

- **D01** Project Foundation and Scenario Definition
- **D02** Stakeholder and RACI Matrix
- **D03** MDM Data Flow and Asset Inventory

2 ASSESS RISK

Rates what could go wrong with those assets.

- **D04** Risk Assessment Methodology and Risk Register

3 DESIGN CONTROLS

Turns each risk into requirements, policy, a standard and access policies.

- **D05** Control Requirements and Framework Crosswalk
- **D06** Mobile Device and BYOD Policy
- **D07** MDM Security Standard
- **D08** Conditional Access Control Design

4 EVIDENCE AND TEST

Checks a risk-based sample of controls against pass conditions set in advance.

- **D09** Evidence Request List and Evidence Index
- **D10** Control Testing Workbook

5 REMEDIATE

Turns each failed or partial test into a finding, a gap, a recommendation and a decision.

- **D11** Findings and Remediation Register
- **D12** Risk Treatment and Retesting Record

6 REPORT

Gives management one readiness position and the decision it needs to make.

- **D13** GRC Workspace and Readiness Dashboard
- **D14** Executive Readiness Report

WORKING RULES

- Every record cites the ID of the record above it. A record with no upstream link is flagged as a traceability gap, not dropped.
- Untested controls and requirements are listed with the reason, never counted as passed.
- Every simulated evidence item and result is labeled as simulated.
- Deliverable IDs MDM-D01 to MDM-D15 are fixed and never reused.

COVERAGE OF THE ORIGINAL EXERCISE

The exercise asked for eight outputs. Each is a deliverable or section that can be read on its own: scope (D01), asset inventory (D03), risk register (D04), control matrix (D05), evidence list (D09), gap analysis and recommendations (D11), and executive summary (D14).

TRACEABILITY

One Risk from Asset to Decision

Business problem 4, data copied to personal storage, followed through every phase. Each link cites the ID of the link above it.

ASSET	**MDM-AST-006** Personal iOS/iPadOS devices used for work.	MDM-D03
RISK	**MDM-RSK-002** Corporate data leakage to personal apps or accounts. Inherent **High (12)**.	MDM-D04
CONTROL	**MDM-CTL-002** Corporate data transfer protection on BYOD. Mapped to SAMA CSF 3.3.10 and NCA ECC.	MDM-D05
EVIDENCE	**MDM-EVD-005** iOS app protection policy export. Rated **Accepted** (simulated).	MDM-D09
TEST	**MDM-TST-001** BYOD data transfer restrictions. Result: **Not Effective** (simulated).	MDM-D10
FINDING AND GAP	**MDM-FND-001** The iOS Share extension moves encrypted corporate files outside managed apps. **Medium (8)**.	MDM-D11
RECOMMENDATION	**MDM-REC-001** Record the platform constraint and submit the remaining exposure to the Business Owner. Owner: IT Operations Manager.	MDM-D11
DECISION	**D-02** The Business Owner **accepts** the exposure, with encryption as the protection, on condition that the retest confirms shared files cannot be opened outside managed apps.	MDM-D12

SECOND BRANCH OF THE SAME RISK

MDM-TST-002 → **MDM-FND-002**: a noncompliant corporate iPhone reaches OneDrive, Medium (9) → **MDM-REC-002**, Mitigate, retest due 14 February 2027. One risk can carry an accepted exposure and a finding under remediation at the same time.

Current residual: Medium (9), provisional (MDM-D12 Section 4). **Target:** Medium (8).

The same chain is held in the records themselves: MDM-D13 Section 2.3 shows it as a worked example. It was not assembled for this summary.

Project Foundation and Scenario Definition

The starting point: the company, its problem, what the assessment covers and how it works.

QUESTION IT ANSWERS

What is being assessed, for whom, within what limits, and how is each step linked to the next?

KEY FACTS

4
business problems
Each linked to a risk in MDM-D04

6
objectives
OBJ-01 to OBJ-06, each with a test of achievement

7
assumptions
AS-01 to AS-07, plus 5 constraints CN-01 to CN-05

8
trace links
From asset to management decision

KEY OUTPUTS

- Business scenario: a fictional Saudi financing company with 850 employees, BYOD allowed and no MDM. Each of the four problems is mapped to a risk ID.
- Scope: in-scope users, device groups, services and information, and 7 exclusions, each with its reason.
- Assumptions and constraints, including SAMA CSF v1.0 as the primary reference and NCA ECC-2:2024 as an adopted baseline.
- The six-phase method and the traceability chain, with its ID formats and chain rules.
- The deliverables map, linking each deliverable to the eight outputs of the original training exercise.
- A simulation statement and a statement separating the exercise scenario from my own work.

RECEIVES

- The training exercise scenario: company size, BYOD without MDM, four problems

HANDS TO

- Scope and objectives to every deliverable
- The four business problems (MDM-D04)
- ID formats and chain rules (MDM-D02 to D14)

View Full Deliverable (PDF) →

Opens the full MDM-D01 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

Stakeholder and RACI Matrix

Who does the work, who is accountable, and who must stay independent.

QUESTION IT ANSWERS

Which role is responsible and accountable for each assessment activity, and how is the GRC function kept from verifying its own work?

KEY FACTS

11
roles
From CISO to employees and contractors

7
activities
In the assessment RACI

1
accountable role
For each activity

3
lines
Operations perform, GRC tests, Internal Audit retests

KEY OUTPUTS

- A stakeholder register: each role's responsibility and the deliverables it appears in.
- An assessment RACI for scoping, evidence, testing, remediation, risk acceptance, retesting and readiness reporting.
- Clear separation: the Business Owner is accountable for risk acceptance, the CISO for the assessment, and the IT Operations Manager for remediation.
- The GRC Analyst prepares and tests but does not operate the service or approve and review access.
- Internal Audit retests items the GRC Analyst prepared.

RECEIVES

- Scope and roles assumption AS-06 (MDM-D01)

HANDS TO

- Control owners and operators (MDM-D05)
- Performed-by and reviewed-by roles (MDM-D10)
- Risk Owner decisions (MDM-D12)

View Full Deliverable (PDF) →

Opens the full MDM-D02 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | **D02** | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

MDM Data Flow and Asset Inventory

What is being protected and how corporate data moves between devices and services.

QUESTION IT ANSWERS

Which devices, services and information sets are in scope, who owns them, and where does corporate data travel?

KEY FACTS

9
assets
MDM-AST-001 to MDM-AST-009

11
data flows
MDM-FLW-001 to MDM-FLW-011

4
device groups
Corporate and personal, Android and iOS/iPadOS

All
Confidential
Under a two-level classification

KEY OUTPUTS

- An asset inventory with type, purpose, owner and classification: 4 device groups, 3 cloud services and 2 information sets.
- Split ownership for personal devices: the employee owns the device, and the company owns only the corporate data inside approved apps.
- A data flow summary covering device management, app protection, sign-in, compliance status and Microsoft 365 traffic.
- A data flow diagram for the proposed architecture, with BYOD using app protection without MDM enrollment.

RECEIVES

- In-scope services and information (MDM-D01 Section 4)

HANDS TO

- Related assets for each risk (MDM-D04)
- Scope of each technical requirement (MDM-D07)
- Scope for evidence and testing (MDM-D09, D10)

View Full Deliverable (PDF) →

Opens the full MDM-D03 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | **D03** | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

Risk Assessment Methodology and Risk Register

What could go wrong with mobile access, how serious it is, and who owns each risk.

QUESTION IT ANSWERS

Which mobile risks matter most, how are they scored, and who decides how each one is treated?

KEY FACTS

8
risks
4 from business problems, 4 introduced by MDM

2
High inherent
MDM-RSK-002 and MDM-RSK-005, both scored 12

5 × 5
scale
Score = Likelihood × Impact, four bands

2
risk owners
Business Owner: 5 risks. CISO: 3 risks

KEY OUTPUTS

- Scoring method: likelihood over 12 months, impact on the highest of C, I or A, four bands from Low (1–4) to Critical (17–25). These thresholds are defined for this case study, not taken from a regulation.
- Three assessment bases: inherent, current residual (credits only controls whose effectiveness is evidenced) and target residual.
- Any risk with Impact 5 goes to management review, whatever its score.
- A Risk Owner for each risk, separate from the control owner in MDM-D05.

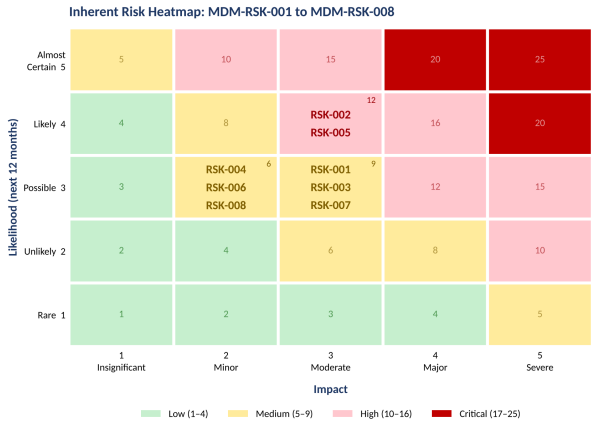


Figure 1 in MDM-D04, reduced. Inherent ratings.

SIMULATED ASSESSMENT RESULT (from MDM-D12 Section 4)

5 of 8 risks were assessed after testing, and none is High. The highest is MDM-RSK-002 at Medium (9), provisional. MDM-RSK-004, 006 and 008 are not assessed because their controls were outside the test sample.

RECEIVES

- Assets MDM-AST-001 to 009 (MDM-D03)
- The four business problems (MDM-D01)

HANDS TO

- Each risk to at least one control (MDM-D05)
- The rating ceiling for findings (MDM-D11)
- Residual risk updates (MDM-D12)

View Full Deliverable (PDF) → Opens the full MDM-D04 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | **D04** | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

Control Requirements and Framework Crosswalk

The controls that treat each risk, and how they map to SAMA and NCA requirements.

QUESTION IT ANSWERS

Which control treats each risk, who owns it, and which regulatory provision does it support, and to what extent?

KEY FACTS

8	16	1 : 1	2
controls	**mappings**	**risk to control**	**control owners**
MDM-CTL-001 to MDM-CTL-008	Each control to SAMA CSF v1.0 and NCA ECC-2:2024	Every risk has at least one control	IT Operations Manager: 7. CISO: 1

KEY OUTPUTS

- A control register: objective, statement, function, nature, design status, owner, operator and measurable parameters for each control.
- Control functions: 3 preventive, 4 preventive and detective, 1 preventive and corrective.
- A framework crosswalk that records a mapping rationale and a mapping limitation for each reference. A mapping shows support, not full compliance.
- Outstanding design items carried forward to MDM-D07, D08 and D09 to D10.
- The administrative access control (MDM-CTL-005) is owned by the CISO, so operations do not approve their own access.

SIMULATED ASSESSMENT RESULT (from MDM-D13 Section 4.3)

No control is rated Implemented: 3 Not Implemented, 2 Partial and 3 not rated because they were not tested.

RECEIVES

- Eight risks with Risk Owners (MDM-D04)
- Roles (MDM-D02)

HANDS TO

- Policy requirements (MDM-D06)
- Technical requirements (MDM-D07)
- Access policies (MDM-D08)
- What to evidence and test (MDM-D09, D10)

View Full Deliverable (PDF) → Opens the full MDM-D05 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | **D05** | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

Mobile Device and BYOD Policy

The rules staff, contractors and IT must follow for corporate and personal devices.

QUESTION IT ANSWERS

What must each role do, and what is allowed or prohibited, when corporate data is accessed from a mobile device?

KEY FACTS

8
sections
From purpose to governance

28
policy requirements
Across five requirement areas

10
roles
Each with defined responsibilities

0
full-device wipes
On personal devices: corporate data only

KEY OUTPUTS

- Authorized use: approved apps only, no mobile browser access, and enrollment and compliance before access on company-owned devices.
- BYOD is voluntary and needs line manager approval. Corporate data stays in approved apps. Removal targets corporate data only, never personal data or the whole device.
- Privacy: a BYOD notice acknowledged before access, minimum data collection, and restricted, reviewed access to employee device reports.
- Contractor lifecycle: sponsor, recorded end date, reminders, revocation that does not wait for device return, and escalation of failures.
- Exceptions with an owner, compensating measures, an expiry date and risk acceptance.
- No individual may approve or review their own access.

RECEIVES

- Controls and owners (MDM-D05)
- Scope (MDM-D01)

HANDS TO

- Requirements to make verifiable (MDM-D07)
- Access rules to enforce (MDM-D08)

View Full Deliverable (PDF) →

Opens the full MDM-D06 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | **D06** | D07 | D08 | D09 | D10 | D11 | D12 | D13 | D14

MDM Security Standard

The technical settings that turn the policy into requirements a tester can verify.

QUESTION IT ANSWERS

What exact configuration must each device group and platform meet, and how is each requirement verified?

KEY FACTS

35
requirements
MDM-STD-001 to MDM-STD-035

8 · 17 · 10
by area
Corporate devices, BYOD app protection, shared

3
management models
Android Fully Managed, iOS ADE supervised, BYOD app protection

6
approved work apps
On personal devices

KEY OUTPUTS

- Management models and technical prerequisites: licensing, enrollment, tokens and certificates.
- For each requirement: scope and traceability, the requirement, the verification method, constraints and status, and the source.
- A dated OS baseline: iOS/iPadOS 27.2 minimum, with the decision on devices still on version 26 recorded and checked against Apple and Microsoft sources.
- BYOD data protection: transfer restrictions, encryption at rest, offline limits and selective wipe with verification.
- Shared requirements: administrative roles and review, report access and accuracy, and contractor revocation.

SIMULATED ASSESSMENT RESULT (from MDM-D13 and MDM-D11)

21 of 35 requirements were tested (60%). Requirements on encryption, data removal, the BYOD notice and browser access have no control, owner or risk (MDM-FND-009).

RECEIVES

- Controls (MDM-D05)
- Policy requirements (MDM-D06)
- Assets (MDM-D03)

HANDS TO

- Device and app conditions (MDM-D08)
- Configuration evidence (MDM-D09)
- Test steps and pass conditions (MDM-D10)

View Full Deliverable (PDF) →

Opens the full MDM-D07 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | **D07** | D08 | D09 | D10 | D11 | D12 | D13 | D14

Conditional Access Control Design

Who can reach Microsoft 365 from a mobile device, and under what conditions.

QUESTION IT ANSWERS

How do the device and app requirements become access decisions that block anything that does not meet them?

KEY FACTS

4	3	6	4
access policies	**groups**	**assumptions**	**limitations**
MDM-CAP-001 to MDM-CAP-004	BYOD approved, Intune admins, emergency access	A-01 to A-06, each with a test or evidence route	L-01 to L-04, each with its handling

KEY OUTPUTS

- Covered by default: corporate devices must be compliant, approved BYOD may use app protection, mobile browsers are blocked, and Intune administrators need phishing-resistant MFA.
- A population table showing which policy applies to each user group, including who is blocked and why.
- Prerequisites, emergency access exclusions, session behavior, access restoration, and a report-only rollout under change management.
- Platform limits stated plainly: blocking access does not remove data already on a device (L-04), and a compliance change can take until token renewal to apply (L-02).
- Assumptions that need proof are sent to testing in MDM-D10, not taken as true.

RECEIVES

- Controls (MDM-D05)
- Access rules (MDM-D06)
- Device and app requirements (MDM-D07)

HANDS TO

- Policy exports to request (MDM-D09)
- Assumptions to test (MDM-D10)
- Limitation L-02 as decision D-01 (MDM-D11, D12)

View Full Deliverable (PDF) →

Opens the full MDM-D08 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | **D08** | D09 | D10 | D11 | D12 | D13 | D14

Evidence Request List and Evidence Index

What proof is needed for each control, who provides it, and whether it was good enough.

QUESTION IT ANSWERS

What evidence shows how each control is set up and operated, and does the evidence received meet the standard?

KEY FACTS (SIMULATED)

75
evidence requests
24 configuration, 51 records

62
Accepted
83% of requests

9
Partial
Missing part stated in the review note

4
Not Provided
Each carried to testing or to MDM-D11

KEY OUTPUTS

- One request per file, with source requirement, type, format and period.
- Request rules: full populations before samples, a three-month default period, 30-day logs, and a re-request for untraceable evidence.
- Separated roles: GRC requests and reviews, IT Operations or IAM provides, and providers never select samples.
- An evidence index with a result and review note for every item, linked to the test that uses it.
- Clear limits: configuration evidence shows set-up, not effectiveness (EL-01).

RECEIVES

- Controls (MDM-D05)
- Requirements (MDM-D07)
- Access policies (MDM-D08)

HANDS TO

- Evidence for each test (MDM-D10)
- Partial and Not Provided items as assurance gaps (MDM-D11)
- Evidence acceptance measure RM-04 (MDM-D13)

View Full Deliverable (PDF) →

Opens the full MDM-D09 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | **D09** | D10 | D11 | D12 | D13 | D14

Control Testing Workbook

Whether the controls actually work, tested step by step against pass conditions set in advance.

QUESTION IT ANSWERS

Which controls work as designed, which do not, and what was left untested and why?

KEY FACTS (SIMULATED)

10
tests
MDM-TST-001 to 010, risk-based sample

2
Effective
MDM-TST-004 and MDM-TST-010

2
Partially Effective
MDM-TST-005 and MDM-TST-009

6
Not Effective
Each linked to a finding

KEY OUTPUTS

- Risk-based sample: two tests for each High risk, one for each risk scored 9, and risks scored 6 deferred with the reason.
- Tests of requirements with no control in MDM-D05 (MDM-TST-008 to 010), so known gaps are tested rather than ignored.
- Each test: objective, evidence used, sample, performer and reviewer, and steps with expected and actual results. Key steps decide the result.
- Independence: GRC tests with read-only access, IT Operations performs device steps under observation, the CISO reviews, and Internal Audit reviews the tests of the CISO's own control.
- A list of 14 untested requirements, each with its reason.

RECEIVES

- Evidence and its review (MDM-D09)
- Pass conditions from requirements and access design (MDM-D07, D08)

HANDS TO

- Failed steps as findings (MDM-D11)
- Control readiness ratings (MDM-D13)
- Effectiveness measure RM-07 (MDM-D13)

View Full Deliverable (PDF) →

Opens the full MDM-D10 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | **D10** | D11 | D12 | D13 | D14

Findings and Remediation Register

What is wrong, how serious it is, what to do about it, and who decides what remains.

QUESTION IT ANSWERS

What gaps did testing reveal, what risk does each leave open, and what action closes it?

KEY FACTS (SIMULATED)

9
findings
8 Medium, 1 Low. Highest: MDM-FND-002 at 9

12
recommendations
Action, owner, due date and success indicator

3
assurance gaps
Untested items with weak evidence, not rated

4
decisions
For the Risk Owner, D-01 to D-04

KEY OUTPUTS

- A findings register: each finding traced to its test, control and risk, rated by impact and likelihood with a written rationale, capped by the risk it relates to.
- Gap analysis: current state, required state, gap and resulting risk for every finding.
- One confirmed design gap (MDM-FND-009): requirements on encryption, data removal, the BYOD notice and browser access have no control, owner or risk. One root cause, one finding.
- Recommendations in priority order: MDM-REC-002 first, then MDM-REC-001.
- Decisions only the Risk Owner can make, each with facts, options and a GRC view.

RECEIVES

- Test results (MDM-D10)
- Evidence gaps (MDM-D09)
- Risk ceilings (MDM-D04)

HANDS TO

- Decisions and the retest plan (MDM-D12)
- Top gaps and immediate action (MDM-D14)

View Full Deliverable (PDF) →

Opens the full MDM-D11 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | **D11** | D12 | D13 | D14

Risk Treatment and Retesting Record

What the Risk Owner decided, how much risk remains, and how each fix will be checked.

QUESTION IT ANSWERS

After testing and decisions, where does each risk stand now, and what would change it?

KEY FACTS (SIMULATED)

5 of 8
risks assessed
3 not assessed: controls untested

0
High residual
Highest MDM-RSK-002, Medium (9), provisional

12
retests
11 by 14 Feb 2027, 1 by 15 May 2027

6
re-rating triggers
Events that reopen a rating or a decision

KEY OUTPUTS

- Six residual risk rules: only tested evidence earns credit (a path counts when its key test step passed), acceptance does not lower a score, and untested risks stay Not assessed.
- Risk Owner decisions on 16 November 2026: D-02 accepted, D-04 accepted with a condition, D-01 pending an assessment, D-03 not yet needed.
- A residual update for each risk: inherent, current and target, and the treatment.
- A retest plan with method, tester and date. A Control Owner never retests their own control, and Internal Audit retests what GRC prepared.
- Re-rating triggers, such as a shared iOS file proving readable, which would return MDM-RSK-002 to High (12).

RECEIVES

- Findings, recommendations and decisions (MDM-D11)
- Scoring method (MDM-D04)

HANDS TO

- Residual risk to the register (MDM-D04)
- Residual and decision measures (MDM-D13)
- Risk level and outlook (MDM-D14)

View Full Deliverable (PDF) → Opens the full MDM-D12 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | **D12** | D13 | D14

GRC Workspace and Readiness Dashboard

One place to see where readiness stands, built from the records, not retyped.

QUESTION IT ANSWERS

How ready is the mobile service, measured consistently, and who must act when it gets worse?

KEY FACTS (SIMULATED)

10	9	20%	NOT READY
registers	measures	control effectiveness	status
Linked by ID, from assets to decisions	RM-01 to RM-09, coverage and outcome	2 of 10 tests effective	As at 16 November 2026

KEY OUTPUTS

- A workspace of ten registers, each with one source, one preparer and one approver.
- Readiness measures with stated thresholds. Coverage is Green only at 100%, because an untested area cannot be called ready.
- Status rules: any Red outcome measure means Not Ready.
- A monthly reporting cadence by audience, and escalation within five working days.

CONTROL READINESS (SIMULATED, MDM-D13 SECTION 4.3)

CTL-001	CTL-002	CTL-003	CTL-004	CTL-005	CTL-006	CTL-007	CTL-008
Not Implemented	Not Implemented	Partial	Not rated	Partial	Not rated	Not Implemented	Not rated

RECEIVES

- Records from MDM-D03 to MDM-D12

HANDS TO

- Status, measures and decisions due (MDM-D14)

View Full Deliverable (PDF) →

Opens the full MDM-D13 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | **D13** | D14

Executive Readiness Report

The five answers senior management needs, and the decision only it can make.

QUESTION IT ANSWERS

How exposed is the company, is it ready, what must happen now, who owns it, and what must management decide?

KEY FACTS (SIMULATED)

MEDIUM
risk level
Within the tested scope

NOT READY
readiness
2 of 10 tests effective

MDM-REC-002
immediate action
IT Operations Manager; retest by 14 Feb 2027

2
decisions
Next test cycle; a date for the D-01 assessment

KEY OUTPUTS

- Risk level and readiness status reported separately, with the reason they differ: Medium risk does not mean ready.
- Top three gaps: iOS data leaving managed control, requirements with no owner, and untested scope.
- An immediate action with a named owner, retester and Risk Owner.
- Two decisions for management, and what happens without them.
- An outlook: if every retest passes, the status becomes Ready with Conditions, stated as a projection, not a result.

RECEIVES

- Findings and recommendations (MDM-D11)
- Residual risk and decisions (MDM-D12)
- Readiness measures (MDM-D13)

HANDS TO

- Senior management, quarterly

View Full Deliverable (PDF) →

Opens the full MDM-D14 on OneDrive (view only).

POSITION IN THE CASE STUDY

D01 | D02 | D03 | D04 | D05 | D06 | D07 | D08 | D09 | D10 | D11 | D12 | D13 | **D14**

CLOSING

Results, Lessons and Limits

KEY RESULTS (SIMULATED)

- Risk level Medium within the tested scope: both High inherent risks fell to Medium.
- Readiness status Not Ready: 2 of 10 tests effective, and no control rated Implemented.
- 9 findings and 12 recommendations, each with an owner, a due date and a retest.
- One full chain from asset to decision, held in the records, not added for this summary.

PRACTICAL VALUE

The case shows how a GRC team can take an access decision such as “allow BYOD” and make it testable: what to protect, what could go wrong, what control applies, what evidence proves it, and who must accept what remains. The same structure can be reused for a real Intune deployment once a tenant exists.

LESSONS LEARNED

- **Coverage matters as much as results.** A Medium risk level said little while three risks were untested, so coverage became its own measure.
- **Requirements added late need an owner.** MDM-D07 gained requirements that MDM-D05 never picked up. The method caught this as a finding (MDM-FND-009) rather than hiding it.
- **Independence has to be designed.** Deciding who performs, who tests and who retests changed the owner of one control and added Internal Audit to the retest plan.
- **A framework mapping is a claim with limits.** Recording what each mapping does not cover made a deviation from SAMA CSF visible and turned it into a decision (D-04).

LIMITS OF THIS ASSESSMENT

- The organization is fictional, and no Microsoft Intune or Entra ID tenant was configured.
- All evidence, test results, ratings, dates and decisions are simulated. They show how the assessment would be performed, not that any control works.
- Stakeholder input and approvals were simulated. The project was prepared by one person.
- Framework references and vendor documentation reflect the versions reviewed at the time of writing.

SOURCE OF THE SCENARIO

The starting scenario is adapted from a training exercise on mobile device risk: the company size, BYOD without MDM, and the four business problems. The risk method, control design, framework mapping, evidence model, test approach and all 14 deliverables are my own work.

View the Full Case Study (PDF) →

Ali Fathi Aldhabiki | linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com